

Security+ 4.6 · Multifactor Authentication

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.6** — Multifactor Authentication (4:29) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: MFA requires two or more factors from DIFFERENT categories: something you know (password/PIN); something you have (token, phone, FIDO2); something you are (biometrics); somewhere you are (location). Password+PIN does not count (same category).

High-Yield Core Concepts Tested on Exam

- MFA: factors of DIFFERENT types — know/have/are
- Password + PIN = SAME category ('know') — NOT MFA
- TOTP: 6-digit code that changes every 30 seconds
- FIDO2: hardware security key for phishing-resistant MFA
- Location can be a factor (somewhere you are)

Exam Tips & Classic Scenarios

- 'combines something you know with something you have' = proper MFA
- 'password + PIN' = not MFA (same category)
- 'one-time code from app' = TOTP (something you have)

Typical Exam Scenario: 'password + physical token' = true MFA; 'password + PIN' = not MFA.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.6 — Multifactor Authentication)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **TOTP:** Time-based One-Time Password: Algorithmic 6-digit passcode regenerated every 30 seconds synchronized with server clocks (RFC 6238).

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. MFA combines factors from different categories. Which trio represents the 3 categories?

- A) Password, PIN, and secret answer
- B) Something you know, something you have, something you are
- C) 3 different passwords
- D) Username, password, and email

2. MFA requires at least two authentication factors. Which combination represents genuine multi-factor authentication?

- A) Password + PIN
- B) Password + Physical token
- C) Two types of biometrics
- D) Security question + Password

3. Corporate scenario (Multifactor Authentication): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'MFA: factors of DIFFERENT TYPE — know/have/are'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: MFA: factors of DIFFERENT TYPE — know/have/are...
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (Multifactor Authentication): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'Password + PIN = SAME category ('something you know') — NOT MFA.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Password + PIN = SAME category ('something you know') — NOT MFA...

5. Corporate scenario (Multifactor Authentication): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'TOTP: 6-digit code that changes every 30s'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: TOTP: 6-digit code that changes every 30s...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Multifactor Authentication): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: "combines something you know with something you have'=proper MFA'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'combines something you know with something you have'=proper MFA...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Multifactor Authentication): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: "password + physical token' = true MFA; 'password + PIN' = not.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'password + physical token' = true MFA; 'password + PIN' = not....
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Multifactor Authentication): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'MFA: factors of DIFFERENT TYPE — know/have/be'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: MFA: factors of DIFFERENT TYPE — know/have/be...

9. Corporate scenario (Multifactor Authentication): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'Password + PIN = SAME category ('something you know') — NOT MFA'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Password + PIN = SAME category ('something you know') — NOT MFA
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Multifactor Authentication): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'TOTP: 6-digit code that changes every 30s'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: TOTP: 6-digit code that changes every 30s...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Something you know, something you have, something you are.

✓ **Why it's correct:** Multi-factor authentication (MFA) requires combining at least two factors from distinct categories. The three classic categories are: something you know (knowledge, such as a password or PIN), something you have (possession, such as a physical token or code-generating app), and something you are (inherence, such as a fingerprint or facial recognition). The option 'Something you know, something you have, something you are' is the only one that correctly lists these three categories, as defined by NIST SP 800-63 and CompTIA Security+ SY0-701. MFA is an access control that mitigates credential compromise risks, as an attacker would need to overcome multiple independent barriers.

✗ **Why the others are wrong:**

- *Password, PIN, and secret answer:* Password, PIN, and secret answer are all examples of 'something you know' (knowledge factor). Although they are authentication mechanisms, they belong to the same category, so they do not constitute true MFA. Using multiple secrets of the same type is called multi-step authentication or apparent multifactor, but it does not meet the requirement of distinct categories. Additionally, secret answers are often vulnerable to social engineering attacks and can be discovered, not offering the same level of security as a second factor from a different category.
- *3 different passwords:* Three different passwords are still only a knowledge factor. Repeating passwords does not add a new authentication category; it only increases complexity within the same category. This is not MFA, because an attacker who compromises the password capture mechanism (e.g., keylogger or phishing) can obtain all three. Security is not multiplied by the number of passwords, but by the diversity of factors. CompTIA Security+ emphasizes that MFA requires factors of different types, not multiple instances of the same type.
- *Username, password, and email:* Username and email are identifiers, not authentication factors. The username and email address are public or easily discovered and do not prove identity. The password is a knowledge factor, but the other two are not authentication factors. Therefore, this combination does not represent MFA. Additionally, email can be used as a channel for sending codes, but by itself it is not a factor; it is a transport medium. The formal definition of MFA requires each factor to be from a different category (knowledge, possession, inherence), and here there is only one real factor.

2) B — Password + Physical token.

✓ **Why it is correct:** The combination ****Password + Physical token**** represents genuine multi-factor authentication because it combines two distinct factors: something you know (the password) and something you have (the physical token, such as a smart card, USB key, or OTP generator device). MFA requires combining at least two of the three classic factors: knowledge (something you know), possession (something you have), and inherence (something you are). In the CompTIA Security+ (SY0-701) syllabus, this distinction is fundamental to avoid false MFA, such as password + PIN, which are both from the same factor (knowledge).

✗ **Why the others are wrong:**

- *Password + PIN:* Password and PIN are both based on knowledge; that is, they represent the same authentication factor (something you know). Even if they are two different secrets, they do not constitute genuine MFA, as there is no combination of distinct factors. An attacker who obtains both (e.g., via keylogger or social engineering) compromises authentication. To be MFA, it is necessary to add a possession or inherence factor. Therefore, this option is incorrect.
- *Two types of biometrics:* Two types of biometrics (e.g., fingerprint and facial recognition) belong

to the same factor: inherence (something you are). Although they are distinct methods, they do not constitute genuine MFA, as they do not combine different factors. MFA requires combining distinct categories (knowledge, possession, inherence). Additionally, biometrics can be problematic if compromised (once leaked, they cannot be changed). Thus, this option does not meet the multi-factor requirement.

- *Security question + Password*: Security questions and passwords are both based on knowledge (something you know). The security question is often used as a second step, but it still belongs to the same factor. Therefore, it is not genuine MFA. Furthermore, security questions are vulnerable to social engineering attacks and can be discovered on social media. To be MFA, it would be necessary to add a possession or inherence factor. Thus, this combination is incorrect.

3) C — Implement the corresponding solution: MFA: factors of DIFFERENT TYPE — know/have/are....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Multifactor Authentication): MFA: factors of DIFFERENT TYPE — know/have/are. Multifactor authentication requires two or more different types of factors: something you know (password, PIN), something you have (smart card, token, phone), something you are (biometrics), and optionally somewhere you are (location) or something you do (behavior). Using multiple factors of the same type (e.g., password + PIN) is not true MFA and is weaker. MFA significantly reduces the risk of credential compromise.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) D — Implement the corresponding solution: Password + PIN = SAME category ('something you know') — NOT MFA....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Multifactor Authentication): Password + PIN = SAME category ('something you know') — NOT MFA. True multifactor authentication requires at least two different categories: something you know, something you have, something you are, or somewhere you are.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) A — Implement the corresponding solution: TOTP: 6-digit code that changes every 30s....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Multifactor Authentication): TOTP: 6-digit code that changes every 30s.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) B — Implement the corresponding solution: 'combines something you know with something you have'=proper MFA....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Multifactor Authentication): 'combines something you know with something you have'=proper MFA. Proper MFA requires at least two different authentication factors, such as a password (knowledge) and a hardware token (possession), significantly enhancing security.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) B — Implement the corresponding solution: 'password + physical token' = true MFA; 'password + PIN' = not....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Multifactor Authentication): 'password + physical token' = true MFA; 'password + PIN' = not. True MFA requires factors from different categories: something you know (password), something you have (physical token), something you are (biometric). A password plus a PIN are both 'something you know', so they are not true MFA. A physical token (e.g., smart card, OTP hardware token) provides 'something you have', thus combining it with a password achieves MFA.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: MFA: factors of DIFFERENT TYPE — know/have/be....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Multifactor Authentication): MFA: factors of DIFFERENT TYPE — know/have/be.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: Password + PIN = SAME category ('something you know') — NOT MFA.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Multifactor Authentication): Password + PIN = SAME category ('something you know') — NOT MFA. MFA requires two or more different categories of authentication factors.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) A — Implement the corresponding solution: TOTP: 6-digit code that changes every 30s....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Multifactor Authentication): TOTP: 6-digit code that changes every 30s.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

